

Monitoring, Notifications & Retention — Product Owner Summary

One-page reference for what this deployment watches, who gets told, and how long every kind of record is kept. Values marked *(param)* are deployment settings in `scripts/deploy.env` — the number shown is the shipped default. `<prefix>` is the deployment's `NAME_PREFIX` (default `claude-gw`).

1. Alarms

All four alarms are CloudWatch alarms created by the stacks. They exist and show state in the AWS console even when no notification topic is configured.

Alarm	What it watches	Fires when	What it means / action
<code><prefix>-certificate-expiry</code> (stack 02)	ACM <code>DaysToExpiry</code> on the imported gateway TLS certificate, checked daily	≤ 30 days (<i>param</i> <code>CERT_EXPIRY_ALARM_DAYS</code>) remain	Imported certificates do not auto-renew. Re-issue with the enterprise CA, publish the new fingerprint to developers, re-import in place.
<code><prefix>-db-rotation-errors</code> (stack 02)	Errors from the database-credential rotation Lambda	≥ 3 errors within 1 hour	Credential rotation is failing repeatedly. Service keeps running on the current credential, but the rotation SLA is not being met — check the Lambda's log group.
<code><prefix>-missing-telemetry</code> (stack 03)	Samples ingested into the AMP metrics workspace (the end-to-end usage/cost pipeline check)	0 samples for 15 consecutive minutes (<i>param</i> <code>MISSING_TELEMETRY_ALARM_MINUTES</code>)	Usage/cost metrics have stopped flowing (gateway down, sidecar unhealthy, IAM/KMS/endpoint breakage, or AMP-side failure). A built-in 30-second heartbeat means an idle fleet does not false-fire. Sends a recovery (OK) notification too.
<code><prefix>-missing-activity-logs</code> (stack 03, off by default)	Events arriving in the AI-activity audit log group	0 events for N minutes (<i>param</i> <code>ACTIVITY_LOGS_ALARM_MINUTES</code> , <i>default</i> 0 = <i>disabled</i>)	The audit stream has stopped delivering. Deliberately off by default: activity is bursty (nights/weekends are silent), so enable only on fleets with continuous activity, with a window longer than the longest expected quiet gap. Sends OK on recovery.

2. SNS Topics

The stacks **do not create any SNS topic**. They accept one optional, organization-provided topic ARN — (*param* `ALARM_SNS_TOPIC_ARN`) — passed to stacks 02 and 03.

Topic	What delivers to it	Message types	Who receives
The org-provided alarms topic (one topic, optional)	All four alarms above	Standard CloudWatch alarm state-change JSON. All four send ALARM ; the two telemetry alarms also send OK (recovery).	Whatever subscriptions the organization attaches to its topic (email, chat webhook, ITSM). Subscriptions are managed outside these stacks.

If `ALARM_SNS_TOPIC_ARN` is left empty, the alarms still exist and show state in the console, but **nobody is notified**. Providing a subscribed topic is an organizational prerequisite for unattended operation.

3. Audit destinations & retention

Everything below is encrypted with the deployment's customer-managed KMS key (CMK) except where noted, and every destination survives a stack teardown (deletion policy: Retain).

Audit record	Destination	Retention	Notes
Spend-cap administration (who set/cleared which cap)	Gateway PostgreSQL <code>admin_audit</code> table	365 days (gateway config)	Actor is the individual admin (<code>oidc:<sub></code>) for portal actions, or the shared key id for the break-glass CLI. Viewable read-only on the portal admin page.
Spend history (metered cost per principal)	Gateway PostgreSQL <code>spend</code> table	13 months (gateway config)	The authoritative cost record (dashboards are observability, not billing).
User identity records	Gateway PostgreSQL	90 days (gateway config)	
Installer downloads + portal admin events (grants, denials, actions)	CloudWatch log group / <code>claude/<prefix>/portal-audit</code>	365 days (<code>param PORTAL_AUDIT_RETENTION_DAYS</code>)	One JSON line per event, including denials. Flag for SIEM ingestion.
AI activity stream (per-user tool inputs, commands, file paths) — opt-in	CloudWatch <code>/claude/<prefix>/activity</code> → Kinesis Firehose → S3 archive bucket (<code>activity/</code> prefix)	CloudWatch window 14 days (<code>param ACTIVITY_LOG_WINDOW_DAYS</code>); durable S3 archive 731 days / 2 years (<code>param ACTIVITY_ARCHIVE_RETENTION_DAYS</code>)	Highly sensitive — IAM-only access, CMK-encrypted, flagged for SIEM. Archive delivery buffers up to 5 minutes. S3 Object Lock was evaluated and deferred by decision (tracked in the security review).
Database statement audit (schema, role, and data changes on the store)	RDS pgaudit → CloudWatch <code>/aws/rds/instance/<prefix>-store/postgresql</code>	731 days / 2 years (<i>CloudFormation parameter <code>PgauditLogRetentionDays</code> on stack 01; template default, not exposed in <code>deploy.env</code></i>)	Captures <code>ddl</code> , <code>role</code> , <code>write</code> classes (<code>param PGAUDIT_LOG_CLASSES</code>); bind parameters excluded so user content stays out of the log.
Bedrock prompt logging (verbatim prompts and model responses) — opt-in, off by default	CloudWatch <code>/claude/<prefix>/bedrock-prompts</code> and an S3 bucket (each gets a full copy; bodies over 100 KB appear only in S3)	CloudWatch window 14 days (<code>param BEDROCK_PROMPT_LOG_WINDOW_DAYS</code>); S3 731 days / 2 years (<code>param BEDROCK_PROMPT_ARCHIVE_RETENTION_DAYS</code>)	Enabled per account+region via <code>BEDROCK_PROMPT_LOGGING=true</code> — captures every Bedrock invocation in the account, not only this gateway's. Does not identify the individual developer (the caller is the gateway's service role); per-user attribution is the AI activity stream above. Highest sensitivity in the deployment: CMK-encrypted, IAM-only, flag for SIEM.
Load-balancer access log (every HTTPS request, source IP, path)	S3 ALB-logs bucket	90 days (<code>param ALB_LOG_RETENTION_DAYS</code>)	SSE-S3 encryption, not the CMK — ELB log delivery does not support KMS (the one deliberate exception; do not "fix").

4. Log destinations & retention (operational)

CloudWatch log groups, CMK-encrypted:

Log group	Contents	Retention
/ecs/<prefix>	Gateway container + telemetry-sidecar stdout/stderr	365 days (fixed)
/aws/lambda/<prefix>-db-bootstrap	One-time database bootstrap Lambda	365 days (fixed)
/aws/lambda/<prefix>-db-rotation	Credential-rotation Lambda (the rotation-errors alarm watches this function)	365 days (fixed)
/ecs/<prefix>-grafana	Grafana container	90 days (fixed)
/ecs/<prefix>-portal	Download-portal container	90 days (<i>param</i> PORTAL_LOG_RETENTION_DAYS)

(The pgaudit, activity, and portal-audit groups in section 3 are also CloudWatch log groups; they are listed there because their content is audit, not operations.)

5. Metric destinations & retention

Destination	What lands there	Retention	Notes
Amazon Managed Prometheus (AMP) workspace	Per-user/team/session usage and cost metrics from every Claude Code client (via the gateway's telemetry sidecar), plus the sidecar's own 30-second heartbeat metrics	150 days — the AMP service default; not set by the templates (raisable via an AWS service-quota request)	Optionally CMK-encrypted (<i>param</i> ENCRYPT_AMP_WITH_CMK ; <i>creation-time only</i> — <i>cannot be enabled later without replacing the workspace and its history</i>). Workspace is retained on stack teardown. Grafana (Okta SSO, at / grafana) visualizes this data; it stores nothing itself.
CloudWatch Metrics (AWS-managed namespaces)	Lambda errors, ACM certificate expiry, AMP ingestion counts, log-delivery counts, ECS Container Insights for the gateway cluster	AWS-managed: 15 months , at progressively coarser resolution (standard CloudWatch behavior, not configurable)	These are what the four alarms evaluate.

Source of truth: `cloudformation/01-04*.yaml` in this repository; alarm runbooks in [om-runbooks.md §9](#) and [cost-controls.md](#) ; finding-level rationale in [../ato/security-assessment-2026-07.md](#) . Regenerate this summary when those change.